

GRC102: Information Security Governance

Assignment 1

Student Name: Diana Wanjiru

Registration Number: C11/26/CGRCE/17188

Submitted to: ICDFA E-Campus

Date: 11 September 2026

Part 1: Governance Structure Analysis

1.1 Governance Weaknesses

#	Weakness / Governance Issue	Potential Business Impact	Effect on International Expansion
1	Security is subordinate to IT operations: the IT Director, not an independent security function, makes most security decisions, conflating operational IT priorities with risk-based security judgement.	Security investment is shaped by IT budget and delivery pressures rather than enterprise risk appetite; no independent challenge function exists to contest risk-accepting decisions.	New jurisdictions bring data-protection, localisation and sector-specific rules (e.g., GDPR-type regimes). An IT-led model lacks the independent authority and cross-functional reach to assess and integrate these obligations.
2	No formal security committee or governance body exists to bring business, legal, compliance and HR stakeholders together.	Decisions are fragmented and inconsistent; risk acceptance varies by individual rather than by policy; emerging risks are addressed slowly.	Expansion requires coordinated decisions across legal, privacy and regional business units. Without a governance body, regional decisions risk being siloed or contradictory.
3	The Board receives only one brief security update per year, far below the continuous oversight good governance requires.	The Board cannot exercise effective fiduciary oversight of cyber risk or ensure adequate resourcing; management is not held accountable between annual updates.	Several regulators (e.g., in financial and data-protection regimes) expect demonstrable, ongoing Board-level cyber oversight; infrequent reporting could itself become a compliance gap in new markets.
4	Security policies are outdated and inconsistently enforced, indicating no formal policy lifecycle (review, approval, communication, enforcement).	Controls lose effectiveness over time, audit and insurance posture weakens, and inconsistent enforcement creates exploitable gaps.	Policies are not localised for new jurisdictions' legal requirements (e.g., employee-monitoring or data-transfer restrictions), creating immediate compliance gaps on entry to new markets.
5	Incidents are handled reactively with no formal governance, classification or escalation process.	Detection and response are delayed, increasing financial and reputational damage and the likelihood of missed statutory notification deadlines.	Breach-notification laws differ markedly by country (e.g., 72-hour rules), and a reactive, ungoverned process risks non-compliance and penalties across multiple regimes simultaneously.

1.2 Proposed Governance Structure

1.2.1 Governance Organisational Chart

The proposed structure separates governance (setting direction and holding management accountable) from management (day-to-day execution), and gives the security function independent standing outside IT operations:

- Board of Directors
 - Board Risk & Technology Committee (oversight, risk appetite approval)
- Chief Executive Officer
 - Chief Information Security Officer (CISO) — reports to CEO, with a direct reporting line to the Board Risk & Technology Committee
 - Executive Security Steering Committee (chaired by CISO)
 - Regional/Business Security Leads
 - IT Security Operations (execution)
 - Internal Audit — reports independently to the Board Audit Committee, providing assurance over the security programme

1.2.2 Key Governance Bodies and Mandates

Body	Mandate
Board Risk & Technology Committee	Approves risk appetite and security strategy; reviews major incidents and audit findings; ensures adequate resourcing; holds the CISO and CEO accountable.
Executive Security Steering Committee (CISO, CFO, COO, Legal/Compliance, HR, business-unit and regional leads)	Aligns security strategy with business objectives; approves policy; oversees risk-treatment decisions; reviews KPIs/KRIs quarterly; coordinates expansion-related security requirements.
Incident Response Governance Team	Classifies and manages significant incidents; executes the escalation protocol to executives and the Board.
Regional Security Working Groups	Localise policy and controls for each jurisdiction entered during expansion; liaise with regional legal/compliance functions.

1.2.3 Responsibilities for Major Governance Roles

- Board / Board Risk & Technology Committee: sets risk appetite, approves strategy and major investments, exercises oversight, and ensures management accountability.
- CISO: owns security strategy, policy, the enterprise risk register, budget, incident governance and Board/committee reporting; independent of IT operations.
- Executive Security Steering Committee: cross-functional decision-making body translating strategy into coordinated action across business units.
- Business-unit and Regional Leads: implement controls locally, own local risk registers, and escalate risks that exceed delegated authority.
- Internal Audit: provides independent assurance on control design and effectiveness, reporting directly to the Board Audit Committee.

1.2.4 Decision-Making, Escalation and Oversight Processes

- A tiered risk-acceptance authority matrix: business owners approve low risks, the CISO approves medium risks, the Steering Committee approves high risks, and the Board Committee approves critical/enterprise-level risks.
- A defined incident severity scale (Sev 1–4) with time-bound escalation, e.g., Sev-1 incidents notified to the CEO and Board Committee chair within 24 hours.
- Continuous oversight through a quarterly KPI/KRI dashboard reviewed by the Steering Committee, with a minimum of quarterly reporting to the Board Committee and ad hoc briefings for major incidents.

1.2.5 Board Involvement and Reporting

The Board Risk & Technology Committee should receive quarterly cyber-risk reporting (covering KRIs, incident trends, audit findings and expansion-related risks), an annual comprehensive strategy review, and immediate briefings for critical incidents. At least one Board member should hold demonstrable cyber/technology risk expertise, and the Committee should periodically participate in incident-response tabletop exercises to test its own readiness.

1.3 Alignment with Governance Principles

The proposed structure reflects three core information security governance principles:

- **Accountability:** every governance layer has a named, non-overlapping owner (Board Committee, CISO, Steering Committee, business leads), removing the ambiguity created by TechCorp's current IT-centric model.
- **Strategic alignment and Board-level oversight:** continuous, structured reporting integrates security into enterprise strategy and risk management rather than treating it as a once-a-year technical update.
- **Risk-based resource allocation:** the tiered risk-acceptance matrix and KPI/KRI framework ensure that effort and investment are directed according to actual risk exposure rather than reactive, ad hoc fixes.

Part 2: Framework Comparison and Selection

2.1 Comparison of COBIT and ISO/IEC 27001

Criterion	COBIT 2019	ISO/IEC 27001:2022
Scope & primary focus	Holistic enterprise governance and management of IT; broader than security alone.	Focused specifically on establishing, operating and improving an Information Security Management System (ISMS).
Structure & major components	Governance and management objectives across five domains (EDM, APO, BAI, DSS, MEA); design factors and capability levels.	Clauses 4–10 (context, leadership, planning, support, operation, evaluation, improvement) plus Annex A controls organised into four themes.
Governance approach	Explicitly separates governance (Evaluate-Direct-Monitor) from management; principle-based and tailorable via design factors.	Governance is embedded via the leadership clause and management review, but the standard is less prescriptive about governance-versus-management separation.
Implementation & certification	Not certifiable at the organisational level; used as an internal governance/maturity assessment tool. Individual professional certification exists.	Certifiable via accredited third-party audit; certification is widely recognised evidence of a functioning ISMS.
Control selection & risk management	Uses the goals cascade and design factors to tailor governance/management objectives enterprise-wide; integrates well with frameworks like COSO.	Mandates a formal risk assessment and a Statement of Applicability (SoA) selecting Annex A controls based on identified risk.
Strengths & limitations	Strength: holistic, strategy-linked IT governance. Limitation: resource-intensive, complex, and not a certifiable security standard.	Strength: internationally recognised certification and clear ISMS discipline. Limitation: narrower scope, less prescriptive on broader enterprise IT governance.
Regulatory alignment / HIPAA	Provides governance-level assurance mechanisms that help demonstrate the management oversight HIPAA expects, but does not map directly to HIPAA safeguards.	Annex A controls can be cross-walked to HIPAA's administrative, technical and physical safeguards; the mandated risk assessment supports HIPAA's required risk analysis.
Resource requirements	Requires broad organisational effort and sustained executive/Board engagement to embed governance objectives.	Requires a dedicated ISMS function, internal audit capability, and budget for external certification and recurring surveillance audits.

2.2 Recommendation for MedSecure

A combined approach is recommended: adopt ISO/IEC 27001 as the primary, certifiable operational ISMS framework, supplemented by COBIT's governance objectives (particularly the Evaluate-Direct-Monitor domain) to strengthen Board and executive oversight.

- Healthcare-sector requirements: patient data demands rigorous confidentiality, integrity and availability controls (ISO's operational discipline) alongside demonstrable Board accountability increasingly expected by regulators (COBIT's governance layer).
- Size and complexity: at 2,000 employees across three states, MedSecure needs a scalable, auditable ISMS (ISO) combined with an enterprise governance overlay (COBIT) to manage distributed operations consistently.
- HIPAA compliance: ISO 27001's Annex A controls cross-walk to the HIPAA Security Rule's safeguards, and its mandatory risk assessment satisfies HIPAA's required risk analysis; certification provides strong evidence for OCR audits and business-associate due diligence.
- Implementation challenges: resource constraints, mapping Annex A controls to HIPAA requirements, and sustaining certification will require dedicated staffing and change management.
- Long-term sustainability: ISO 27001's Plan-Do-Check-Act cycle combined with COBIT's capability-maturity model supports continued organisational evolution as MedSecure grows.

2.3 High-Level Implementation Roadmap

Phase	Timeframe	Key Activities
1. Initiation & Gap Assessment	Months 1–3	Scope the ISMS; conduct a gap analysis against ISO 27001 and HIPAA; secure executive sponsorship; establish the governance committee (COBIT EDM).
2. Risk Assessment & Design	Months 4–6	Conduct a formal risk assessment; develop the Statement of Applicability; draft policies and a risk-treatment plan.
3. Control Implementation	Months 7–10	Deploy technical, administrative and physical controls; deliver workforce training and awareness; document the ISMS.
4. Internal Audit & Management Review	Months 11–12	Conduct internal audits; complete corrective actions; hold formal management review (Clause 9).
5. Certification Audit	Months 13–15	Undergo Stage 1 and Stage 2 external certification audits; achieve ISO/IEC 27001 certification.
6. Continual Improvement	Ongoing	Annual surveillance audits; three-year recertification cycle; periodic COBIT maturity reassessment.

Critical success factors include sustained executive sponsorship, adequate budget and staffing, clear accountability, integration with the existing HIPAA compliance programme, and effective change management. Likely challenges — resource constraints, staff resistance, and mapping complexity — can be mitigated through a phased rollout, targeted communication and training, and use of established

HIPAA-to-ISO 27001 crosswalk references. A realistic total timeline to initial certification is 15–18 months, reflecting MedSecure's multi-state, 2,000-employee scope.

Part 3: Case Study Analysis — Equifax Data Breach

The 2017 Equifax breach, which exposed the data of approximately 147 million people, is a well-documented example of governance failure rather than a purely technical failure. This section analyses five governance failures, describes preventive governance structures a CISO could have established, and draws wider lessons.

3.1 Governance Failures

#	Governance Issue	Contribution to the Breach / Impact	Governance Principle Not Applied
1	Fragmented and unclear accountability for vulnerability remediation.	The Apache Struts vulnerability, notified in March 2017, was never successfully patched on the affected systems, directly enabling the breach.	Clear accountability and ownership: responsibility was not assigned, tracked and verified to closure.
2	Inadequate Board oversight of cyber risk.	Congressional scrutiny found the Board received insufficient, inconsistent information and could not exercise effective oversight of cyber risk.	Board-level oversight and integration of cyber risk into enterprise risk management.
3	Weak vulnerability and patch-management governance, with no enforced SLA or verification process.	The vulnerability remained unpatched for months; scanning processes failed to confirm remediation across affected systems.	Continuous monitoring and assurance: controls were not independently verified as operating effectively.
4	Poor network segmentation.	Once the initial portal was compromised, the lack of segmentation allowed lateral movement, turning a contained intrusion into a massive data exfiltration.	Security-by-design / defense-in-depth: governance did not translate policy into enforced technical architecture.
5	An expired SSL inspection certificate went unnoticed for an extended period.	Expired monitoring capability blinded detection tooling, delaying discovery of the intrusion for roughly ten weeks (breach began in May, was discovered 29 July 2017).	Operational control governance: no process ensured that critical monitoring controls remained continuously operative.

3.2 Preventive Governance Structure (as CISO before the breach)

- Governance bodies and responsibilities: establish an enterprise Cyber Risk Committee (CISO, CIO, Legal, Internal Audit, business-unit representatives) and a Board Technology & Risk Committee with direct, unfiltered CISO access and quarterly reporting.

- Accountability mechanisms: assign named system and application owners; enforce SLA-based patch policy (e.g., critical vulnerabilities remediated within 30 days) with automated tracking and mandatory escalation for SLA breaches; tie remediation performance to executive KPIs.
- Risk management processes: maintain a formal enterprise risk register that integrates cyber risk; validate vulnerability scans against a complete, current asset inventory; require documented executive sign-off for any risk-acceptance exception.
- Board reporting and oversight: provide a quarterly cyber-risk dashboard tracking KRIs such as critical-vulnerability aging and patch-SLA compliance; define an immediate escalation protocol for critical vulnerabilities and severe incidents; commission an annual independent security assessment reported directly to the Board.
- Policy enforcement: implement a mandatory patch-management policy with enforced deadlines, automated compliance scanning, defined consequences for non-compliance, and integration into the change-management process.
- Vulnerability management governance: maintain a centralised, continuously updated asset inventory; run continuous vulnerability scanning against a defined severity/SLA matrix; independently verify remediation (not merely ticket closure) through audit.

3.3 Wider Governance Lessons

- Changes in regulatory expectations: rules such as the SEC's cybersecurity disclosure requirements — mandating disclosure of material incidents and of Board cyber-governance practices — reflect a direct regulatory response to failures of the kind seen at Equifax.
- Evolution of Board involvement: expectations have shifted from passive annual updates toward demonstrable, ongoing Board-level cyber oversight, including Board members with relevant expertise and regular structured briefings.
- Executive accountability: the resignations of Equifax's CSO and CIO illustrate a broader trend toward personal executive accountability for security failures, reinforced in some jurisdictions by direct regulatory action against individual security executives.
- Lessons for organisations with similar risk profiles: organisations holding large volumes of sensitive or regulated data must treat vulnerability management as a governance issue rather than a purely technical one, ensure segmentation limits the impact of any compromise, continuously verify that monitoring controls remain operative, and embed cyber risk genuinely into enterprise risk management with active Board engagement.

Part 4: Governance Principles Application

As newly appointed CISO of GlobalFinance — a decentralised, 15,000-employee financial-services organisation operating across 20 countries — the following eight governance principles are proposed to provide consistency while respecting legitimate regional differences.

4.1 Information Security Governance Principles

1. Accountability & Ownership

- Principle: Every asset, process and risk has a single named accountable owner.
- Importance in financial services: Financial regulators across jurisdictions expect clear, demonstrable accountability chains.
- Application in practice: RACI matrices; regional CISOs report into a Group CISO with a dotted line to local regulators/executives.
- Implementation challenge: Overlapping accountability between global functions and regionally autonomous business units.

2. Risk-Based Decision-Making

- Principle: Security decisions are proportionate to actual risk rather than uniformly applied.
- Importance in financial services: Balances cost and business agility across regions with very different threat and regulatory profiles.
- Application in practice: A common risk taxonomy and scoring methodology applied consistently but locally.
- Implementation challenge: Achieving consistent risk quantification across varied regional environments.

3. Global Baseline, Local Flexibility

- Principle: A mandatory minimum control baseline applies everywhere, with permitted local enhancements.
- Importance in financial services: Ensures a consistent security floor while accommodating legitimate regional legal and operational differences.
- Application in practice: A mandatory minimum control set (e.g., aligned to a recognised framework) plus an approved-variance process for regional additions.
- Implementation challenge: Defining a genuine floor without it becoming a lowest common denominator; regional resistance.

4. Compliance by Design

- Principle: Regulatory requirements are built into processes and products from inception, not bolted on afterward.
- Importance in financial services: GlobalFinance operates under diverse, heavily regulated financial-services regimes across 20 countries.
- Application in practice: Compliance checkpoints embedded in change- and product-governance gates.

- Implementation challenge: Keeping pace with rapidly diverging and changing regional regulation.

5. Transparency & Continuous Reporting

- Principle: Security posture is visible to leadership on an ongoing basis via standard metrics.
- Importance in financial services: Enables timely, risk-informed decisions at both regional and global levels.
- Application in practice: A standardised KPI/KRI dashboard rolled up from region to Group CISO to Board.
- Implementation challenge: Ensuring data quality and consistency across disparate regional systems.

6. Independent Assurance

- Principle: Security effectiveness is independently verified rather than self-assessed.
- Importance in financial services: Builds regulator and customer trust and removes self-assessment bias in a high-stakes sector.
- Application in practice: Regular internal/external audits and penetration testing, with findings tracked centrally.
- Implementation challenge: Resourcing a consistent assurance capability across all 20 countries.

7. Proportional Centralised Oversight, Distributed Execution

- Principle: Policy and standards are set centrally; execution and local risk decisions are delegated.
- Importance in financial services: Preserves business-unit agility while maintaining enterprise-wide risk visibility.
- Application in practice: Global policy set centrally; regional teams implement and tailor execution within delegated limits, with a defined escalation path.
- Implementation challenge: Avoiding the central function becoming a bottleneck, or regions drifting from standards.

8. Continuous Improvement & Learning

- Principle: Lessons from incidents and audits are systematically fed back into governance.
- Importance in financial services: The financial-services threat landscape evolves quickly; static governance becomes obsolete.
- Application in practice: Post-incident reviews, a periodic policy/principle review cycle, and cross-regional benchmarking.
- Implementation challenge: Capturing and sharing lessons consistently across 20 countries and multiple business silos.

4.2 Balancing Competing Needs

- Global consistency vs. local flexibility: the baseline-plus-tailoring model (Principle 3) sets a common floor while a governance committee approves regional variances.

- Security requirements vs. business agility: risk-based, proportional oversight (Principles 2 and 7) avoids blanket heavy controls, applying lighter-touch requirements to lower-risk activities to preserve speed.
- Compliance obligations vs. innovation: compliance-by-design (Principle 4) embeds regulatory checks early in development pipelines rather than as late-stage blockers, supported by a sandbox/exception process for pilots.
- Centralised oversight vs. distributed responsibility: layered governance (Principles 1 and 7) has the centre set policy and monitor enterprise-wide KRIs while regional leaders own execution and local risk decisions within delegated authority limits.

4.3 Governance Mechanism for Adherence

- Measurement and reporting: quarterly regional self-assessments against a principle-based maturity scorecard, validated periodically by independent audit, consolidated into a global dashboard for the Group CISO and Board Risk Committee.
- Accountability at different levels: Board (ultimate oversight and risk-appetite approval) → Group CISO (global policy owner and escalation point) → Regional CISOs/Security Leads (implementation accountability and local regulator liaison) → business-unit owners (control execution).
- Handling exceptions or conflicts: a formal exception-request process requiring a documented risk assessment and time-bound remediation plan, approved by the Group CISO (or the Board committee for material exceptions), with a defined escalation path for regional-versus-global disagreements.
- Review and continuous improvement: an annual principle review incorporating incident learnings, a regulatory-change scan, regional feedback sessions and benchmarking against recognised frameworks, with revisions approved by the Board.

References

Federal Trade Commission. (2019). Equifax data breach settlement. <https://www.ftc.gov/enforcement/refunds/equifax-data-breach-settlement>

ISACA. (2019). COBIT 2019 framework: Introduction and methodology. ISACA.

International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.

Securities and Exchange Commission. (2023). Cybersecurity risk management, strategy, governance, and incident disclosure (Final rule, Release Nos. 33-11216; 34-97989).

U.S. Department of Health and Human Services, Office for Civil Rights. (n.d.). The HIPAA Security Rule. <https://www.hhs.gov/hipaa/for-professionals/security/>

U.S. Government Accountability Office. (2018). Data protection: Actions taken by Equifax and federal agencies in response to the 2017 breach (GAO-18-559). <https://www.gao.gov/products/gao-18-559>

U.S. House of Representatives, Committee on Oversight and Government Reform. (2018). The Equifax data breach: Majority staff report.

von Solms, R., & van Niekerk, J. (2013). From information security to cyber security. *Computers & Security*, 38, 97–102.